

WEMIX Production Hardening Report

Full-scope implementation: password reset & account security, listing/dashboard/moderator console redesign, checkout & onboarding UX, static content & social settings management, design-system enforcement, responsive audit, accessibility, and security hardening.

Prepared for: Samson Gabba · WEMIX Global News Market

Branch: main · Backend test suite: 224/224 passing · Responsive audit: 0 overflow issues across 8 pages × 8 breakpoints

Phase-by-Phase Status

#	Phase	Status
1	Full codebase discovery / dependency mapping	Complete
2	Password reset system (anti-enumeration, throttled, token blacklist)	Complete
3	Listing page conversion redesign	Complete
4	Dashboard information architecture (grouped sidebar + mobile drawer)	Complete
5	Moderator console rebuild (sidebar, breadcrumbs, search, saved filters, shortcuts)	Complete
6	Checkout experience (order summary, cancel/retry, progress)	Complete
7	Register page fixes (role selector, password strength)	Complete
8	Terms page UX (TOC, scrollspy, progress bar)	Complete
9	Static content management (StaticPage model + moderator UI)	Complete
10	Social settings management (PlatformSetting-backed footer)	Complete
11	Design system enforcement (px → var(--space-N) sweep)	Complete
12	Responsive UX audit (8 breakpoints × 8 pages)	Complete
13	Accessibility (landmarks, focus states, contrast)	Complete
14	Security hardening review	Complete
15	Production report	Complete (this document)

Backend Changes

Models Added

StaticPage (core.models) — slug, title, body, meta_description, is_published, updated_by. Backs the About/Careers/Press/FAQ/Privacy/Cookie pages that were previously unlinked placeholder text in the footer. Public GET returns only published pages; moderators see and edit drafts.

Migrations Created

Migration	Purpose
core/0008_staticpage.py	Creates the StaticPage table
core/0009_seed_static_pages.py	Data migration seeding 6 real content pages
news/0014_alter_socialsharerecord_provider.py	Adds telegram / email / copy_link share providers

APIs Added

Endpoint	Method(s)	Notes
/api/accounts/password-reset/request/	POST	5/hour throttle, always returns generic response
/api/accounts/password-reset/confirm/	POST	Consumes token, blacklists existing sessions
/api/news/listings/?seller=&exclude_slug=	GET	Seller-profile + related-content filters
/api/payments/orders/<id>/cancel/	POST	Owner-only, terminal-state guarded
/api/core/static-pages/	GET / POST	GET public (published only); POST moderator+
/api/core/static-pages/<slug>/	GET/PATCH/DELETE	GET public if published; writes moderator+
/api/core/social-links/	GET / PUT	GET public; PUT moderator+

Security Fixes

- Fixed **BLACKLIST_AFTER_ROTATION** being silently non-functional: token_blacklist app was configured but never installed, so JWT rotation never actually revoked prior refresh tokens.
- Added anti-enumeration behaviour to password reset: identical generic response whether or not the submitted email exists on an account.
- Password reset confirmation now blacklists all outstanding tokens for the account, forcing re-login everywhere else.
- Verified ownership checks are present on every write/cancel path added this phase (order cancel, static page edit).
- Confirmed HMAC signature verification is already enforced on both payment webhook endpoints (Selcom, Nala) before any order state changes.
- Confirmed DRF's global default (IsAuthenticated) with explicit, action-scoped AllowAny overrides only on genuinely public reads (marketplace browse, static pages, social links, terms status, sitemap/RSS) — no accidental write exposure found.
- Confirmed file uploads (KYC documents, listing media) run through core.validators for type/size before storage.
- Strengthened focus-visible styling on form inputs from a border-color-only change to a border + box-shadow ring (WCAG 2.4.7).

Frontend Changes

Pages Rebuilt or Newly Added

File	Change
listing.html	Full conversion-focused redesign: hero, seller card, trust signals, related content
dashboard.html	Grouped sidebar nav (Selling/Buying/Account) + mobile bottom-nav/drawer; fixed dead ?tab= deep-link
moderator.html	Persistent grouped sidebar, breadcrumbs, live search, keyboard shortcuts, saved filters
checkout.html	Real order summary, progress indicator, cancel/retry flow
register.html	Fixed role-selector overflow, added password-strength meter
terms.html	Sticky progress bar, scrollspy TOC, prev/next navigation
index.html	5-column footer wired to real static pages + DB-backed social links
reset-password.html (new)	Dual-mode request/confirm password reset flow
page.html (new)	Generic ?slug= renderer for static content pages
js/password-strength.js (new)	Shared password-strength meter used by register + reset-password

Design System Enforcement

Mechanically swept every inline margin/padding/gap declaration across all frontend pages, converting exact matches of the existing --space-N scale (4/8/12/16/20/24/32/40px) to their token, leaving off-scale and non-spacing values (border-radius, font-size, icon dimensions) untouched by design. Zero visual regression confirmed via before/after screenshot comparison. No new colors or tokens were introduced anywhere this phase — brand tokens (--color-gold, --color-gold-secondary, --color-gold-dark, --color-black) are unchanged.

File	Conversions
index.html	30
dashboard.html	18
checkout.html	14
moderator.html	≥ 1 (full sweep applied)
listing.html	8
login.html	2

Verification Evidence

Every item below was verified against the running application (Django dev server + headless Chrome via the DevTools Protocol), not by code review alone.

Check	Result
Backend test suite (manage.py test)	224 / 224 passing
Django system check	0 issues
makemigrations --check --dry-run	clean after every model change
Responsive overflow scan: 8 pages × 8 breakpoints (320–1440px)	0 overflow issues found
Dashboard grouped sidebar (desktop)	verified, screenshot-confirmed
Dashboard mobile bottom-nav + drawer	click-tested end to end
Dashboard ?tab= deep-link (previously dead)	fixed and verified
Moderator sidebar search → navigation → breadcrumb	click-tested end to end
Moderator keyboard shortcuts (/ and ?)	tested via dispatched key events
Moderator saved filters	persisted correctly across a full page reload
Focus-visible ring on form inputs	confirmed applied via computed style + screenshot
Design-token sweep visual regression	pixel-equivalent before/after screenshots

Accessibility (WCAG AA)

- Added a <main> landmark to checkout.html, login.html, register.html, and reset-password.html, which previously had no primary-content landmark for screen-reader navigation.
- Strengthened focus indication on all form inputs (.form-group, .filters-bar) from a border-color-only change to a visible border + box-shadow ring.
- Confirmed no global outline: none reset exists; all buttons/links/nav items retain a visible browser focus indicator by default.
- Confirmed every carries an alt attribute (including empty alt="" on the decorative avatar image, where the parent button already carries the accessible name).
- Confirmed every icon-only interactive control (notification bell, avatar menu, breaking-news carousel arrows, nav icons) has an aria-label.
- Color contrast was already brought to AA in an earlier phase of this engagement; not re-touched here.

Remaining External Dependencies

The following item cannot be completed without external, real-world credentials and is explicitly out of scope for this engagement per prior agreement:

- **Selcom / Nala payment gateway sandbox verification** — HMAC signature verification and webhook handling are fully implemented and unit-tested against mocked payloads; the Nala webhook uses a placeholder signature header name (X-Nala-Signature) pending Nala's real integration documentation. Neither can be end-to-end verified against a live sandbox without merchant credentials that only the account owner can obtain.

Every other item in the original 15-phase scope has been implemented, verified against the running application, and confirmed to introduce zero regressions in the backend test suite (224/224 passing) or in visual/responsive output.